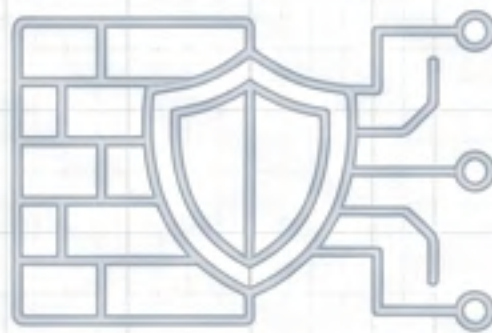




UFW

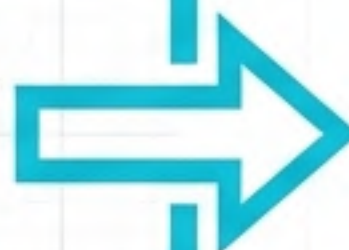


Snort 3



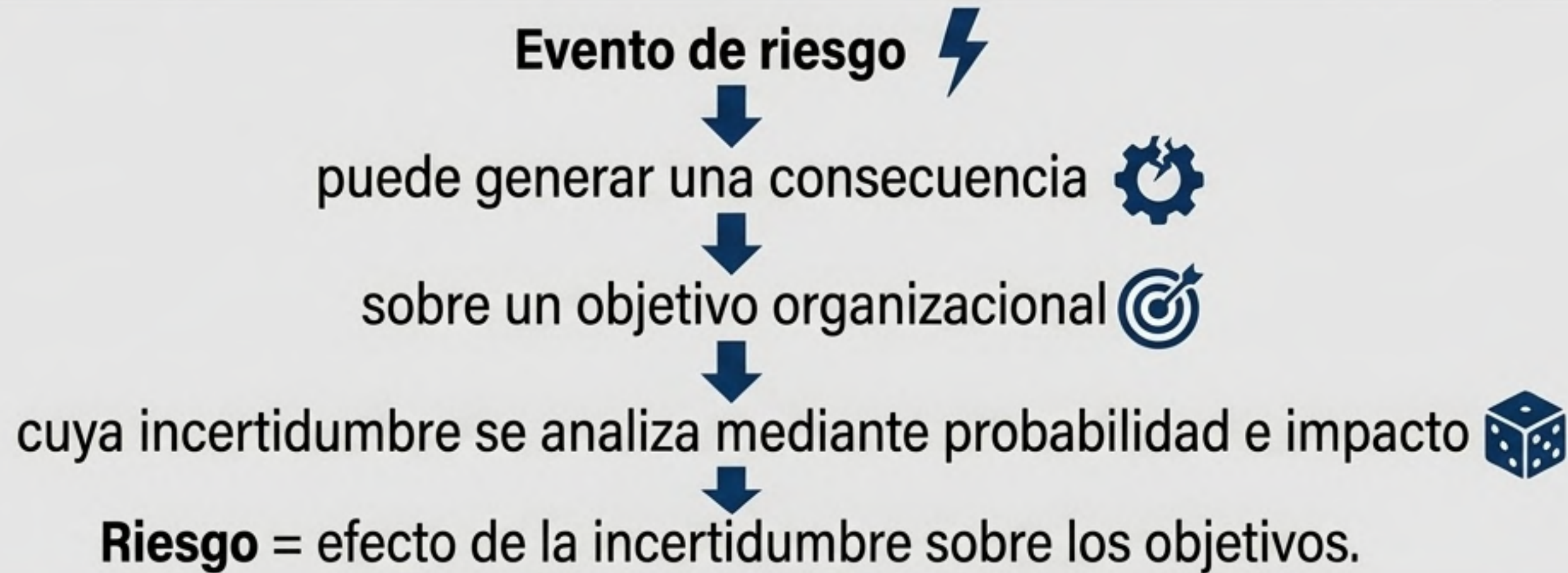
Cyber Kill Chain

Lección 07: Contexto, criterios y gobierno del riesgo



- **De los bits al negocio:** Ya dominas firewalls, IDS y validación de controles.
- **La nueva pregunta:** ¿Qué objetivos organizacionales pueden verse afectados por una falla técnica, y con qué reglas decidiremos si realmente importa?
- **Regla de oro:** Sin contexto no hay criterio. Sin criterio, una puntuación es solo una opinión con un número.

Riesgo y Objetivos: El Efecto de la Incertidumbre

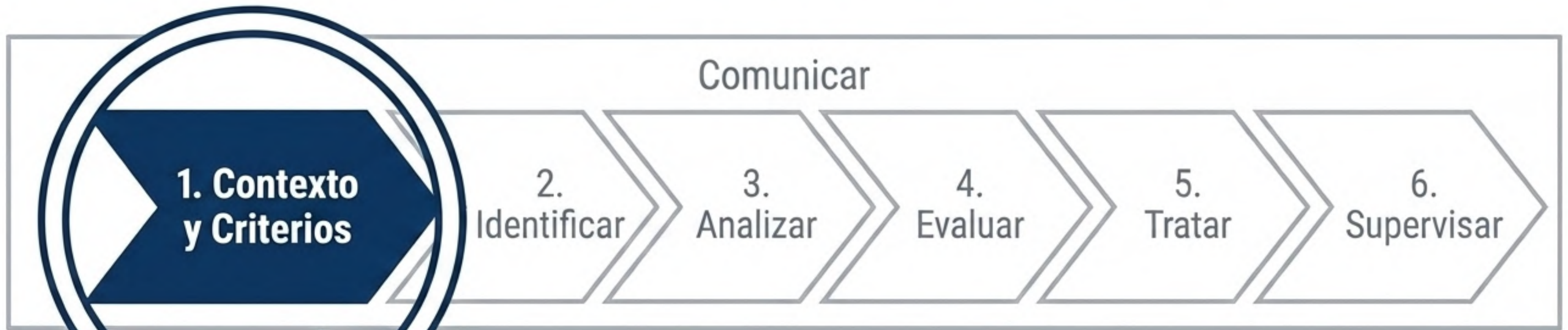


Riesgo Residual: Riesgo que permanece después de aplicar medidas de tratamiento o controles.

Ejemplo: AeroCargo (Empresa Logística)

- **Vulnerabilidad:** Falta de parche en servidor. (NO es un riesgo por sí solo).
- **Escenario Evaluable:** Si un ransomware cifra el servidor durante el despacho, los camiones no pueden salir, afectando el objetivo de entrega en 24 horas.

El Mapa de Ruta: Preparando la Cancha



ESTA LECCIÓN

- **Definir** las reglas del juego.
- **Establecer** umbrales.
- **Asignar** responsabilidades.

ADVERTENCIA

En esta etapa **NO** asignamos puntajes ni niveles de riesgo, **NO** evaluamos riesgos concretos y **NO** proponemos tratamientos.

Contexto Externo: El Ecosistema Ineludible

NIST CSF 2.0: GV.OC
(Contexto Organizacional)

Obligaciones Legales:

Fijan requisitos mínimos que la organización no puede tratar como simples preferencias.

Ejemplos en Chile:

- Ley 19.628, actualmente vigente.
- Ley 21.663, Ley Marco de Ciberseguridad.
- Ley 21.719, publicada y con entrada en vigencia el 1 de diciembre de 2026.



Contratos: Exigencias legales de terceros. Pueden pesar más que una preferencia interna.

Expectativas de Clientes:

Definen el estándar de confianza y el daño reputacional en caso de incidente.



La Organización

Terceros y Proveedores:

Introducen dependencias críticas y riesgos que la organización no controla directamente.



Contexto Interno: El Valor de las Restricciones

Lo clásico (El contexto estándar)	Las restricciones reales (El contexto crítico)
• Objetivos del negocio • Estructura organizacional • Cultura corporativa • Procesos y capacidades	• Presupuesto cerrado e inamovible • Falta de personal dedicado a seguridad • Ventanas de congelamiento de cambios (Ej. Diciembre) • Sistemas legados inmodificables



Ignorar las restricciones convierte un análisis de riesgos en una lista de deseos inejecutable. Declararlas no es resignación: es la diferencia entre un plan profesional y una fantasía.

Objetivo y Alcance: Transformando Peticiones Vagas

Por favor evaluar todos los riesgos de la empresa antes de la próxima campaña.



ESPECIFICACIÓN TÉCNICA DE ALCANCE

1. **Periodo:** Ventana temporal exacta (Ej. Octubre a Diciembre).
2. **Inclusiones:** Procesos, sistemas y datos específicos (Ej. Venta online, BD Clientes).
3. **Exclusiones Explícitas:** Qué queda fuera (Ej. Red de sucursales físicas).
4. **Riesgo de la Exclusión:** [Obligatorio] Qué peligro introduce esta omisión y quién lo asume.
5. **Autoridad:** Quién aprueba el documento final.

(Vago, inalcanzable, inauditable)

La Cadena de Valor: De Objetivos a Procesos Críticos



Regla de Oro: Crítico no significa simplemente importante.
Si un sistema tecnológico no está estrictamente unido a un objetivo de negocio declarado y a una ventana temporal concreta, **no es crítico.**

Partes Interesadas: Interés vs. Autoridad



Confundir **tener interés** con tener **autoridad** genera **parálisis analítica** donde se consulta mucho y no se **decide nada**.

Criterios de Riesgo: Las Reglas del Juego

Componentes de los Criterios

-  **Escalas de Probabilidad:** Cómo mediremos la frecuencia empírica.
-  **Dimensiones de Impacto:** Cómo mediremos el daño al negocio.
-  **Apetito y Tolerancia:** Cuánto riesgo soportaremos operativamente.
-  **Criterios de Aceptación:** Bajo qué condiciones un riesgo puede mantenerse sin tratamiento adicional, mediante una decisión formal y trazable.
-  **Reglas de Escalamiento:** Cuándo debe intervenir la alta gerencia.

¿Por qué fijar reglas antes de evaluar?

Definir las escalas de impacto después de ver los riesgos descubiertos permite ajustar los números artificialmente para obtener la conclusión deseada.

La objetividad requiere que las reglas se escriban antes de jugar.

Escalas de Probabilidad: El Poder de lo Observable

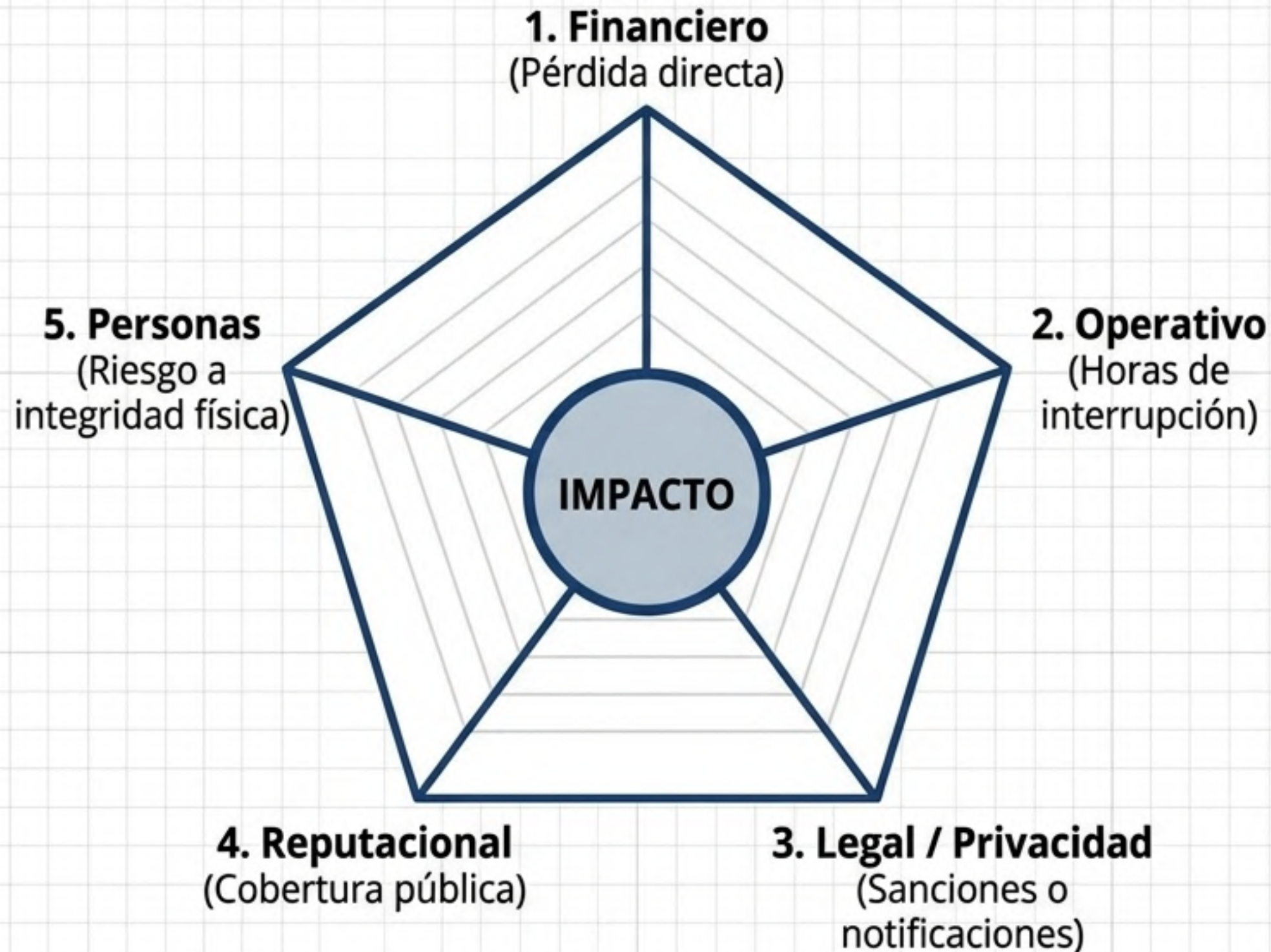
Nivel	Escala Vaga (Inútil)	Descriptor Observable (Correcto)
1	Muy Baja	0 casos en 24 meses y sin condiciones previas.
2	Baja	0 casos en 24 meses, pero existe la vulnerabilidad.
3	Media	1 caso registrado en los últimos 24 meses.
4	Alta	Entre 2 y 9 casos en los últimos 24 meses.
5	Muy Alta	10 o más casos en 24 meses, o condición ya activa.

(Falla: Cada persona interpreta Medio de manera distinta)

(Éxito: Datos empíricos reproducibles por cualquier analista)

Un criterio que no se puede observar empíricamente, no es un criterio.

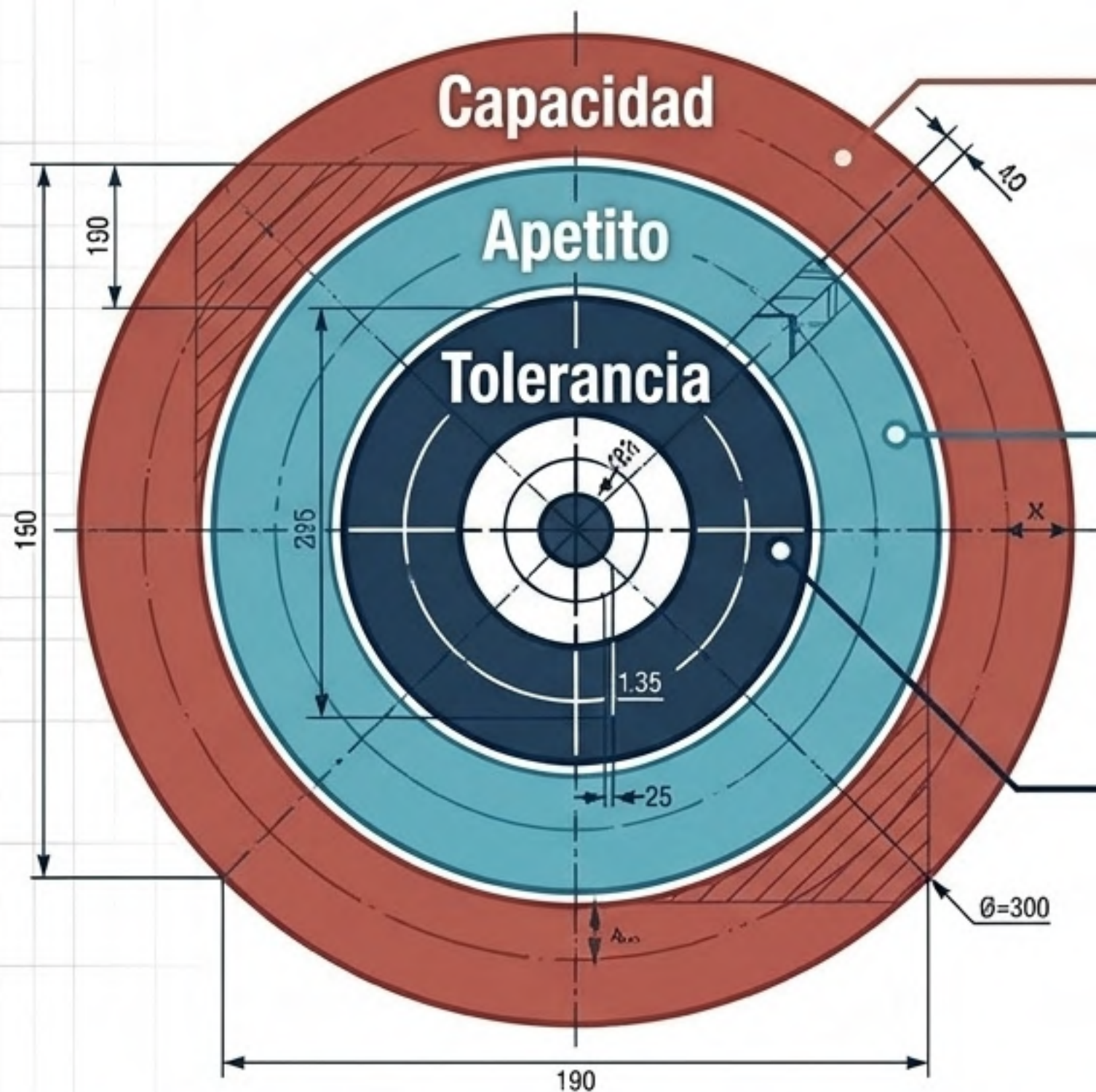
Dimensiones de Impacto: Calibración a la Realidad



Regla de Calibración

El impacto debe ser estrictamente proporcional al tamaño del negocio. Un umbral de impacto Catastrófico fijado en **\$1 millón de pesos** es absurdo si la empresa factura \$18.000 millones al año. Si el nivel más alto se cruza todos los días, la escala no distingue nada.

Apetito, Tolerancia y Capacidad



Capacidad (La Ruina):

El riesgo máximo absoluto que la organización puede soportar sin ir a la quiebra, cerrar o perder su licencia de operación.

Apetito (La Estrategia):

Declaración cualitativa de la dirección sobre cuánto riesgo queremos asumir para crecer (Ej. Aceptamos riesgos operativos bajos para innovar rápido).

Tolerancia (El Tripwire):

El límite operativo, táctico y medible. Debe incluir unidad, periodo y umbral exacto (Ej. Máximo 1 interrupción de base de datos mayor a 4 horas por trimestre).

Un criterio que no se puede observar empíricamente, no es un criterio.

Obligaciones No Negociables



El Mito

Tenemos un apetito de riesgo alto frente a la fuga de datos personales.

La Realidad

El cumplimiento de las leyes (como la Ley de Protección de Datos 19.628 / 21.719) y de contratos firmados NO es una preferencia de negocio.

Regla de Gobierno

Las obligaciones legales definen un umbral mínimo irrenunciable. No se puede tener apetito por incumplir la ley. Cualquier riesgo que cruce una línea legal activa inmediatamente el Criterio de Escalamiento.

Propiedad del Riesgo: ¿Quién Responde Realmente?

Propietario del Riesgo (Autoridad)	Responsable Interno del Control	Área de Seguridad (Facilitador)
Rol: Gerencia Comercial u Operativa. Función: Toma la decisión final de aceptación o tratamiento. Prueba de fuego: ¿Puede autorizar presupuesto o detener el proceso por completo? Si no, no es el dueño.	Rol: Área o cargo interno encargado de coordinar y asegurar la operación del control. Función: Implementa, administra o supervisa el control y reúne evidencia de su funcionamiento. Proveedor externo: Puede actuar como ejecutor del control, pero no reemplaza al responsable interno.	Rol: CISO, Analistas. Función: Analiza, diseña metodologías, advierte y consolida el registro de riesgos.

El Mito Destruído: Si un riesgo operacional cae por defecto en el Área de Seguridad como su propietario, el análisis del contexto está mal diseñado.

Cierre: Supuestos, Datos Faltantes y Síntesis

Documentando la Incertidumbre - Honestidad Intelectual	
Dato Faltante:	SLA de disponibilidad del proveedor de hosting.
Supuesto Provisional:	Asumimos que no hay garantía formal de uptime.
Quién lo tiene:	El departamento de administración de contratos.
Qué cambiaría si es falso:	Si existe un SLA contractual con compromisos de disponibilidad, compensaciones o penalizaciones, cambiarían las opciones de respuesta y la evaluación de la dependencia del proveedor.

